

Course: GRC 102 - Information Security Governance
Assessment: Week 4 Lab-Assignment - Monitoring and Auditing Security Controls
Student: Sisanda Lisa Masango
Registration Number: C11/26/CGRCE/17572
Date: 02 October 2026

Executive Summary

This security assessment evaluated the system hardening, auditing, and log management posture of a Kali Linux environment by configuring kernel-level monitoring with `auditd`, querying binary system journals via `journalctl`, and conducting an automated baseline audit using Lynis. Analysis of system logs revealed that modern default configurations route authentication and system events through `systemd-journald` rather than legacy `/var/log` paths, requiring adapted `journalctl` queries to maintain complete operational visibility. Initial audit results identified critical configuration gaps, including an unconfigured host firewall (`FIRE-4512`), missing brute-force protection mechanisms (`DEB-0880`), and unisolated temporary file storage across user sessions (`DEB-0280`). These risks were successfully remediated by deploying `ufw` with default-deny rules, implementing `fail2ban` for automated log-based IP banning, and configuring `libpam-tmpdir` to enforce private session temp directories. Retesting verified that these controls effectively reduced system attack surfaces, improved compliance alignment with frameworks such as ISO/IEC 27001, and elevated the overall system hardening index.

Scope and Authorisation

- **Target System:** Assigned Kali Linux Virtual Machine (aarch64 architecture running on UTM hypervisor).
- **Authorized Scope:**
 - Installation and rule configuration of the Linux Audit Daemon (`auditd`).
 - System journal inspection and log parsing (`journalctl`).
 - Automated security auditing and posture evaluation using Lynis.
 - Package installation and safe system hardening (`ufw`, `fail2ban`, `libpam-tmpdir`).
- **Boundaries:** All testing and remediation activities were restricted strictly to the local assigned laboratory VM environment. External network probing, unauthorized privilege escalation attempts, and invasive exploit payloads were explicitly out of scope.

Methodology

The assessment followed a structured four-stage evaluation lifecycle:

1. **Kernel System Call Auditing (`auditd`):** Configured `/etc/audit/rules.d/custom.rules` to monitor file integrity (`/etc/passwd`, `/etc/shadow`) and track execution of privileged system commands.
2. **Binary Journal Analysis (`journalctl`):** Queried `systemd-journald` structures to analyze authentication attempts, privileged `sudo` command executions, and system priority errors (`-p err`).
3. **Automated Security Assessment (Lynis):** Performed a comprehensive Unix system scan to measure compliance, calculate a baseline Hardening Index, and categorize vulnerabilities by severity.
4. **Governance Framework Mapping:** Mapped technical findings to enterprise control frameworks, including ISO/IEC 27001 (A.12 Operations Security, A.13 Network Security) and NIST CSF 2.0 (PR.AC, DE.CM).

Module 1 System Auditing with auditd

Auditd is installed evidence

A terminal window on a Kali Linux system showing the installation and status of the auditd service. The window title is 'kali@kali: ~'. The terminal output shows the installation of auditd (1:4.1.2-1+b2) and related packages. The user then runs 'sudo systemctl start auditd' and 'sudo systemctl enable auditd'. The status of the service is shown as 'active (running)'. The terminal also displays the auditd service's configuration and logs.

```
kali@kali: ~  
File Actions Edit View Help  
Setting up auditd (1:4.1.2-1+b2) ...  
update-rc.d: We have no instructions for the auditd init script.  
update-rc.d: It looks like a non-network service, we enable it.  
audit-rules.service is a disabled or a static unit, not starting it.  
auditd.service is a disabled or a static unit, not starting it.  
Setting up ldap-utils (2.6.14+dfsg-2) ...  
Setting up audispd-plugins (1:4.1.2-1+b2) ...  
Processing triggers for libc-bin (2.43-4) ...  
Processing triggers for man-db (2.11.2-3) ...  
Processing triggers for kali-menu (2023.4.3) ...  
  
(kali@kali)-[~]  
$ sudo systemctl start auditd  
  
(kali@kali)-[~]  
$ sudo systemctl enable auditd  
Synchronizing state of auditd.service with SysV service script with /lib/systemd/systemd-sysv-install.  
Executing: /lib/systemd/systemd-sysv-install enable auditd  
Created symlink /etc/systemd/system/multi-user.target.wants/auditd.service → /lib/systemd/system/auditd.service.  
  
(kali@kali)-[~]  
$ sudo systemctl status auditd  
● auditd.service - Security Audit Logging Service  
   Loaded: loaded (/lib/systemd/system/auditd.service; enabled; preset: disabled)  
   Active: active (running) since Fri 2026-10-02 06:52:55 PDT; 27s ago  
     Docs: man:auditd(8)  
           https://github.com/linux-audit/audit-documentationyou are able to hear"  
   Main PID: 21118 (auditd)  
     Tasks: 2 (limit: 4549)  
    Memory: 580.0K  
       CPU: 10ms  
   CGroup: /system.slice/auditd.service  
           └─21118 /usr/sbin/auditd  
  
Oct 02 06:52:55 kali systemd[1]: Starting auditd.service - Security Audit Logging Service ...  
Oct 02 06:52:55 kali auditd[21118]: No plugins found, not dispatching events  
Oct 02 06:52:55 kali auditd[21118]: Init complete, auditd 4.1.2 listening for events (startup state enable)  
Oct 02 06:52:55 kali systemd[1]: Started auditd.service - Security Audit Logging Service.  
  
(kali@kali)-[~]  
$
```

Figure 1: Auditd is running

Configure Audit Rules

```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali)-[~]  
$ sudo systemctl enable auditd  
Synchronizing state of auditd.service with SysV service script with /lib/systemd/systemd-sysv-install.  
Executing: /lib/systemd/systemd-sysv-install enable auditd  
Created symlink /etc/systemd/system/multi-user.target.wants/auditd.service → /lib/systemd/system/auditd.service.  
(kali@kali)-[~]  
$ sudo systemctl status auditd  
● auditd.service - Security Audit Logging Service  
   Loaded: loaded (/lib/systemd/system/auditd.service; enabled; preset: disabled)  
   Active: active (running) since Fri 2026-10-02 06:52:55 PDT; 27s ago  
     Docs: man:auditd(8)  
           https://github.com/linux-audit/audit-documentation  
   Main PID: 21118 (auditd)  
     Tasks: 2 (limit: 4549)  
    Memory: 580.0K  
       CPU: 10ms  
   CGroup: /system.slice/auditd.service  
           └─21118 /usr/sbin/auditd  
  
Oct 02 06:52:55 kali systemd[1]: Starting auditd.service - Security Audit Logging Service ...  
Oct 02 06:52:55 kali auditd[21118]: No plugins found, not dispatching events  
Oct 02 06:52:55 kali auditd[21118]: Init complete, auditd 4.1.2 listening for events (startup state enable)  
Oct 02 06:52:55 kali systemd[1]: Started auditd.service - Security Audit Logging Service.  
(kali@kali)-[~]  
$ sudo nano /etc/audit/rules.d/custom.rules  
# See the man page for more details on auditd configuration, the more you are able to hear"  
(kali@kali)-[~]  
$ sudo systemctl restart auditd  
(kali@kali)-[~]  
$ sudo auditctl -l  
-w /etc/passwd -p rwx -k passwd_changes  
-w /etc/shadow -p rwx -k shadow_changes  
-a always,exit -F arch=b64 -S execve -F key=program_execution  
-a always,exit -F arch=b32 -S execve -F key=program_execution  
-w /var/log/auth.log -p wa -k auth_failures  
(kali@kali)-[~]  
$
```

Figure 2: Loaded custom rules

Generate and Query Audit Events

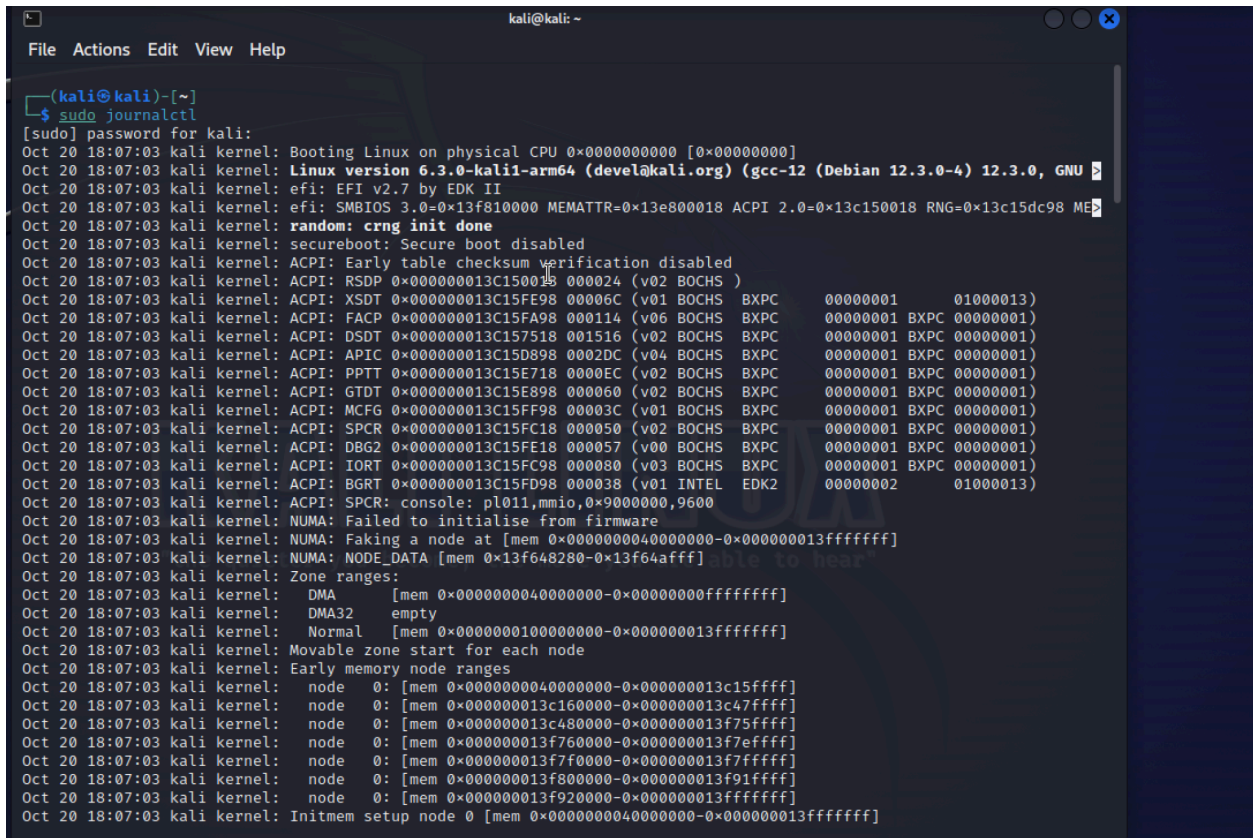
```
kali@kali:~  
File Actions Edit View Help  
d=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0  
type=PATH msg=audit(1790950389.661:3092): item=0 name="/usr/bin/sudo" inode=2129975 dev=fe:02 mode=0104755 ouid=0 ogi  
d=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0  
type=CWD msg=audit(1790950389.661:3092): cwd="/home/kali"  
type=EXECVE msg=audit(1790950389.661:3092): argc=4 a0="sudo" a1="ausearch" a2="-k" a3="program_execution"  
type=SYSCALL msg=audit(1790950389.661:3092): arch=c00000b7 syscall=221 success=yes exit=0 a0=ffffccb33070 a1=ffffbdf6  
3a00 a2=aaaac34d1d0 a3=0 items=3 ppid=1479 pid=31398 uid=1000 uid=1000 gid=1000 euid=0 suid=0 fsuid=0 egid=1000 sgi  
d=1000 fsgid=1000 tty=pts0 ses=2 comm="sudo" exe="/usr/bin/sudo" subj=unconfined key="program_execution"  
  
time→Fri Oct 2 07:13:09 2026  
type=PROCTITLE msg=audit(1790950389.681:3106): proctitle=6175736561726368002D6B0070726F6772616D5F657865637574696F6E  
type=PATH msg=audit(1790950389.681:3106): item=2 name="/lib/ld-linux-aarch64.so.1" inode=2104949 dev=fe:02 mode=01007  
55 ouid=0 ogid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0  
type=PATH msg=audit(1790950389.681:3106): item=1 name="/usr/sbin/ausearch" inode=2105387 dev=fe:02 mode=0100755 ouid=  
0 ogid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0  
type=PATH msg=audit(1790950389.681:3106): item=0 name="/usr/sbin/ausearch" inode=2105387 dev=fe:02 mode=0100755 ouid=  
0 ogid=0 rdev=00:00 nametype=NORMAL cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0  
type=CWD msg=audit(1790950389.681:3106): cwd="/home/kali"  
type=EXECVE msg=audit(1790950389.681:3106): argc=3 a0="ausearch" a1="-k" a2="program_execution"  
type=SYSCALL msg=audit(1790950389.681:3106): arch=c00000b7 syscall=221 success=yes exit=0 a0=aaaaae5e5a18 a1=aaaaae5d  
bb0c a2=aaaaae5e2880 a3=ffff87dc0000 items=3 ppid=31399 pid=31400 uid=1000 uid=0 gid=0 euid=0 suid=0 fsuid=0 egid=0  
sgid=0 fsgid=0 tty=pts1 ses=2 comm="ausearch" exe="/usr/sbin/ausearch" subj=unconfined key="program_execution"  
  
(kali@kali)~  
$ sudo ausearch -k auth_failures  
  
time→Fri Oct 2 07:05:13 2026  
type=PROCTITLE msg=audit(1790949913.848:151): proctitle=2F7362696E2F617564697463746C002D52002F6574632F61756469742F617  
56469742E72756C6573  
type=PATH msg=audit(1790949913.848:151): item=0 name="/var/log/" inode=2883760 dev=fe:02 mode=040755 ouid=0 ogid=0 rd  
ev=00:00 nametype=PARENT cap_fp=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0  
type=CWD msg=audit(1790949913.848:151): cwd="/"  
type=SOCKADDR msg=audit(1790949913.848:151): saddr=1000000000000000000000000000000000  
type=SYSCALL msg=audit(1790949913.848:151): arch=c00000b7 syscall=206 success=yes exit=1088 a0=3 a1=ffffcb747b00 a2=a4  
40 a3=0 items=1 ppid=22734 pid=27393 audit=4294967295 uid=0 gid=0 euid=0 suid=0 fsuid=0 egid=0 sgid=0 fsgid=0 tty=(non  
e) ses=4294967295 comm="auditctl" exe="/usr/sbin/auditctl" subj=unconfined key=(null)  
type=CONFIG_CHANGE msg=audit(1790949913.848:151): audit=4294967295 ses=4294967295 subj=unconfined op=add_rule key="aut  
h_failures" list=4 res=1  
  
(kali@kali)~  
$
```

Figure 3: Auth Failure Evidence

800-53) by establishing non-repudiable log evidence necessary for forensic investigation and continuous threat detection.

Module 2 Log Management and Analysis

Exploring Logs with journalctl



```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali)~  
$ sudo journalctl  
[sudo] password for kali:  
Oct 20 18:07:03 kali kernel: Booting Linux on physical CPU 0x000000000 [0x00000000]  
Oct 20 18:07:03 kali kernel: Linux version 6.3.0-kali1-arm64 (devel@kali.org) (gcc-12 (Debian 12.3.0-4), GNU  
Oct 20 18:07:03 kali kernel: efi: EFI v2.7 by EDK II  
Oct 20 18:07:03 kali kernel: efi: SMBIOS 3.0=0x13f810000 MEMATTR=0x13e800018 ACPI 2.0=0x13c150018 RNG=0x13c15dc98 ME  
Oct 20 18:07:03 kali kernel: random: crng init done  
Oct 20 18:07:03 kali kernel: secureboot: Secure boot disabled  
Oct 20 18:07:03 kali kernel: ACPI: Early table checksum verification disabled  
Oct 20 18:07:03 kali kernel: ACPI: RSDP 0x0000000013C150018 000024 (v02 BOCHS )  
Oct 20 18:07:03 kali kernel: ACPI: XSDT 0x0000000013C15FE98 00006C (v01 BOCHS BXPC 00000001 01000013)  
Oct 20 18:07:03 kali kernel: ACPI: FACP 0x0000000013C15FA98 000114 (v06 BOCHS BXPC 00000001 BXPC 00000001)  
Oct 20 18:07:03 kali kernel: ACPI: DSDT 0x0000000013C157518 001516 (v02 BOCHS BXPC 00000001 BXPC 00000001)  
Oct 20 18:07:03 kali kernel: ACPI: APIC 0x0000000013C15D898 0002DC (v04 BOCHS BXPC 00000001 BXPC 00000001)  
Oct 20 18:07:03 kali kernel: ACPI: PPTT 0x0000000013C15E718 0000EC (v02 BOCHS BXPC 00000001 BXPC 00000001)  
Oct 20 18:07:03 kali kernel: ACPI: GTDT 0x0000000013C15E898 000060 (v02 BOCHS BXPC 00000001 BXPC 00000001)  
Oct 20 18:07:03 kali kernel: ACPI: MCFG 0x0000000013C15FF98 00003C (v01 BOCHS BXPC 00000001 BXPC 00000001)  
Oct 20 18:07:03 kali kernel: ACPI: SPCR 0x0000000013C15FC18 000050 (v02 BOCHS BXPC 00000001 BXPC 00000001)  
Oct 20 18:07:03 kali kernel: ACPI: DBG2 0x0000000013C15FE18 000057 (v00 BOCHS BXPC 00000001 BXPC 00000001)  
Oct 20 18:07:03 kali kernel: ACPI: IORT 0x0000000013C15FC98 000080 (v03 BOCHS BXPC 00000001 BXPC 00000001)  
Oct 20 18:07:03 kali kernel: ACPI: BGRT 0x0000000013C15FD98 000038 (v01 INTEL EDK2 00000002 01000013)  
Oct 20 18:07:03 kali kernel: ACPI: SPCR: console: pl011,mmio,0x90000000,9600  
Oct 20 18:07:03 kali kernel: NUMA: Failed to initialise from firmware  
Oct 20 18:07:03 kali kernel: NUMA: Faking a node at [mem 0x0000000040000000-0x000000013ffffffff]  
Oct 20 18:07:03 kali kernel: NUMA: NODE_DATA [mem 0x13f648280-0x13f64afff]  
Oct 20 18:07:03 kali kernel: Zone ranges:  
Oct 20 18:07:03 kali kernel: DMA [mem 0x0000000040000000-0x000000013ffffffff]  
Oct 20 18:07:03 kali kernel: DMA32 empty  
Oct 20 18:07:03 kali kernel: Normal [mem 0x0000000100000000-0x000000013ffffffff]  
Oct 20 18:07:03 kali kernel: Movable zone start for each node  
Oct 20 18:07:03 kali kernel: Early memory node ranges  
Oct 20 18:07:03 kali kernel: node 0: [mem 0x0000000040000000-0x000000013c15ffff]  
Oct 20 18:07:03 kali kernel: node 0: [mem 0x000000013c160000-0x000000013c47ffff]  
Oct 20 18:07:03 kali kernel: node 0: [mem 0x000000013c480000-0x000000013f75ffff]  
Oct 20 18:07:03 kali kernel: node 0: [mem 0x000000013f760000-0x000000013f7effff]  
Oct 20 18:07:03 kali kernel: node 0: [mem 0x000000013f7f0000-0x000000013f7fffff]  
Oct 20 18:07:03 kali kernel: node 0: [mem 0x000000013f800000-0x000000013f91ffff]  
Oct 20 18:07:03 kali kernel: node 0: [mem 0x000000013f920000-0x000000013ffffffff]  
Oct 20 18:07:03 kali kernel: Initmem setup node 0 [mem 0x0000000040000000-0x000000013ffffffff]
```

Figure 5: journalctl exploration evidence

```
kali@kali: ~  
File Actions Edit View Help  
  
(kali@kali)-[~]  
$ sudo less /var/log/auth.log  
/var/log/auth.log: No such file or directory  
  
(kali@kali)-[~]  
$ sudo grep -i "error" /var/log/syslog  
grep: /var/log/syslog: No such file or directory  
  
(kali@kali)-[~]  
$ sudo grep -i "warning" /var/log/syslog  
grep: /var/log/syslog: No such file or directory  
  
(kali@kali)-[~]  
$ sudo journalctl -n 20  
Oct 02 07:49:46 kali dbus-daemon[911]: [session uid=1000 pid=911] Activating service name='org.xfce.Xfconf' requested  
Oct 02 07:49:46 kali dbus-daemon[911]: [session uid=1000 pid=911] Successfully activated service 'org.xfce.Xfconf'  
Oct 02 07:50:53 kali auditd[27369]: Audit daemon rotating log files  
Oct 02 07:52:40 kali sudo[51094]:    kali : TTY=pts/0 ; PWD=/home/kali ; USER=root ; COMMAND=/usr/bin/less /var/log  
Oct 02 07:52:40 kali sudo[51094]: pam_unix(sudo:session): session opened for user root(uid=0) by (uid=1000)  
Oct 02 07:52:40 kali sudo[51094]: pam_unix(sudo:session): session closed for user root  
Oct 02 08:41:22 kali systemd[1]: Starting phpsessionclean.service - Clean php session files ...  
Oct 02 08:41:23 kali systemd[1]: phpsessionclean.service: Deactivated successfully.  
Oct 02 08:41:23 kali systemd[1]: Finished phpsessionclean.service - Clean php session files.  
Oct 02 08:42:04 kali sudo[51589]:    kali : TTY=pts/0 ; PWD=/home/kali ; USER=root ; COMMAND=/usr/bin/grep -i error  
Oct 02 08:42:04 kali sudo[51589]: pam_unix(sudo:session): session opened for user root(uid=0) by (uid=1000)  
Oct 02 08:42:04 kali sudo[51589]: pam_unix(sudo:session): session closed for user root  
Oct 02 08:43:25 kali sudo[52284]:    kali : TTY=pts/0 ; PWD=/home/kali ; USER=root ; COMMAND=/usr/bin/grep -i warni  
Oct 02 08:43:25 kali sudo[52284]: pam_unix(sudo:session): session opened for user root(uid=0) by (uid=1000)  
Oct 02 08:43:25 kali sudo[52284]: pam_unix(sudo:session): session closed for user root  
Oct 02 08:45:01 kali CRON[53048]: pam_unix(cron:session): session opened for user root(uid=0) by (uid=0)  
Oct 02 08:45:01 kali CRON[53049]: (root) CMD (command -v debian-sa1 > /dev/null && debian-sa1 1 1)  
Oct 02 08:45:01 kali CRON[53048]: pam_unix(cron:session): session closed for user root  
Oct 02 08:45:52 kali sudo[53482]:    kali : TTY=pts/0 ; PWD=/home/kali ; USER=root ; COMMAND=/usr/bin/journalctl -n  
Oct 02 08:45:52 kali sudo[53482]: pam_unix(sudo:session): session opened for user root(uid=0) by (uid=1000)  
lines 1-20/20 (END)
```

Figure 6: System Log review

Error Warning Evidence

```
kali@kali: ~  
File Actions Edit View Help  
  
(kali@kali)-[~]  
$ sudo journalctl -p err -n 15  
Oct 02 07:17:54 kali spice-vdagentd[1172]: No QXL devices found, not generating xorg.conf  
Oct 02 07:19:56 kali spice-vdagentd[1172]: No QXL devices found, not generating xorg.conf  
Oct 02 07:21:31 kali spice-vdagentd[1172]: No QXL devices found, not generating xorg.conf  
Oct 02 07:21:43 kali spice-vdagentd[1172]: No QXL devices found, not generating xorg.conf  
Oct 02 07:23:37 kali spice-vdagentd[1172]: No QXL devices found, not generating xorg.conf  
Oct 02 07:26:10 kali spice-vdagentd[1172]: No QXL devices found, not generating xorg.conf  
Oct 02 07:26:12 kali spice-vdagentd[1172]: No QXL devices found, not generating xorg.conf  
Oct 02 07:35:44 kali spice-vdagentd[1172]: No QXL devices found, not generating xorg.conf  
Oct 02 07:36:46 kali spice-vdagentd[1172]: Error getting active session: No data available  
Oct 02 07:36:46 kali spice-vdagentd[1172]: Error getting active session: No data available  
Oct 02 07:42:07 kali lightdm[43122]: gkr-pam: unable to locate daemon control file  
Oct 02 07:42:07 kali spice-vdagentd[1172]: No QXL devices found, not generating xorg.conf  
Oct 02 07:42:07 kali spice-vdagentd[1172]: No QXL devices found, not generating xorg.conf  
Oct 02 07:42:07 kali lightdm[42977]: pam_systemd(lightdm-greeter:session): Failed to release session: Transport endp  
Oct 02 07:42:08 kali spice-vdagentd[1172]: No QXL devices found, not generating xorg.conf  
lines 1-15/15 (END)
```

KALI LINUX

"the quieter you become, the more you are able to hear"

Figure 7: journalctl - err evidence

```
kali@kali: ~  
File Actions Edit View Help  
  
(kali@kali)~$ sudo journalctl _COMM=sudo | tail -n 15  
Failed to add match '_COMM=sudo': Invalid argument  
  
(kali@kali)~$ sudo journalctl _COMM=sudo | tail -n 15  
Oct 02 07:52:40 kali sudo[51094]: pam_unix(sudo:session): session closed for user root  
Oct 02 08:42:04 kali sudo[51589]: kali : TTY=pts/0 ; PWD=/home/kali ; USER=root ; COMMAND=/usr/bin/grep -i error /var/log/syslog  
Oct 02 08:42:04 kali sudo[51589]: pam_unix(sudo:session): session opened for user root(uid=0) by (uid=1000)  
Oct 02 08:42:04 kali sudo[51589]: pam_unix(sudo:session): session closed for user root  
Oct 02 08:43:25 kali sudo[52284]: kali : TTY=pts/0 ; PWD=/home/kali ; USER=root ; COMMAND=/usr/bin/grep -i warning /var/log/syslog  
Oct 02 08:43:25 kali sudo[52284]: pam_unix(sudo:session): session opened for user root(uid=0) by (uid=1000)  
Oct 02 08:43:25 kali sudo[52284]: pam_unix(sudo:session): session closed for user root  
Oct 02 08:45:52 kali sudo[53482]: kali : TTY=pts/0 ; PWD=/home/kali ; USER=root ; COMMAND=/usr/bin/journalctl -n 20  
Oct 02 08:45:52 kali sudo[53482]: pam_unix(sudo:session): session opened for user root(uid=0) by (uid=1000)  
Oct 02 08:46:55 kali sudo[53482]: pam_unix(sudo:session): session closed for user root  
Oct 02 08:47:28 kali sudo[54304]: kali : TTY=pts/0 ; PWD=/home/kali ; USER=root ; COMMAND=/usr/bin/journalctl _COMM=sudo  
Oct 02 08:47:28 kali sudo[54304]: pam_unix(sudo:session): session opened for user root(uid=0) by (uid=1000)  
Oct 02 08:47:28 kali sudo[54304]: pam_unix(sudo:session): session closed for user root  
Oct 02 08:47:44 kali sudo[54447]: kali : TTY=pts/0 ; PWD=/home/kali ; USER=root ; COMMAND=/usr/bin/journalctl _COMM=sudo  
Oct 02 08:47:44 kali sudo[54447]: pam_unix(sudo:session): session opened for user root(uid=0) by (uid=1000)  
  
(kali@kali)~$
```

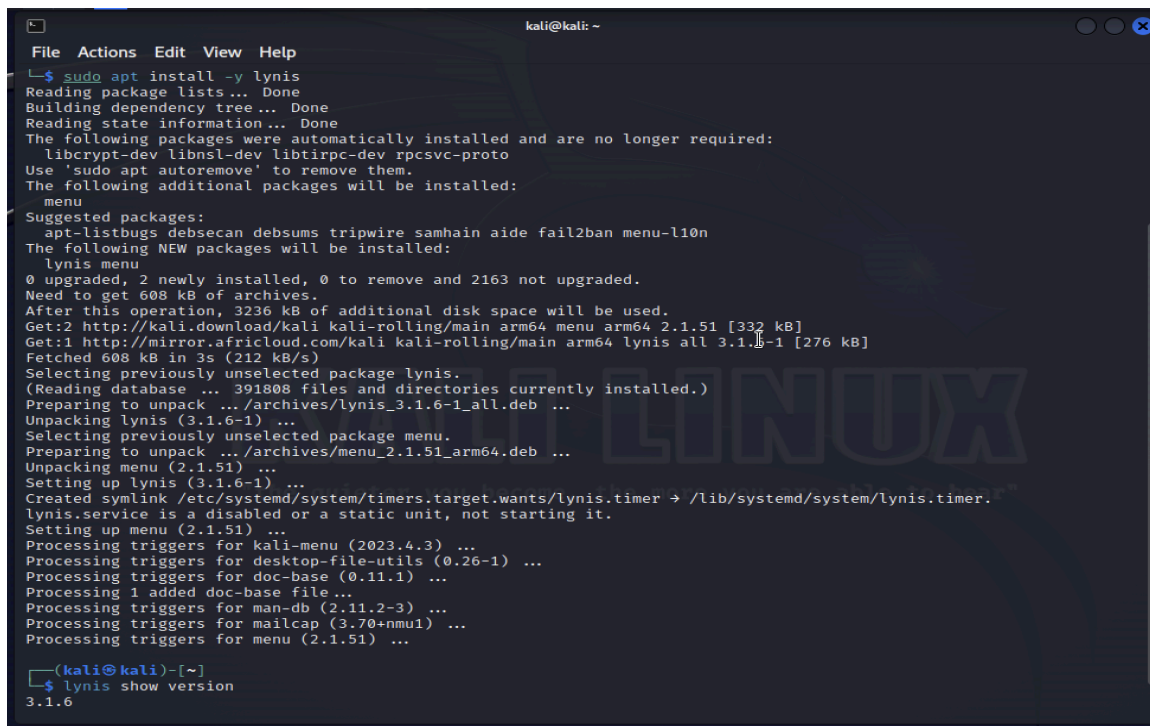
Figure 8: Privilege use evidence

Event Analysis Table

Event / Condition	Evidence Source	Time	User / Service	Security Significance	Recommended Action
Privilege Elevation Execution	journalctl _COMM=sudo	Oct 02 08:43:25	kali (as root) / sudo	Confirms elevated privilege execution (COMMAND=/usr/bin/grep -i warning /var/log/syslog). Validates user accountability for administrative operations.	Monitor system logs regularly to ensure sudo execution correlates with authorized operational changes.
Cron Job Scheduled Activity	journalctl -n 20	Oct 02 08:45:01	root / CRON	Automatic system task execution (CMD (command -v debian-sa1...)) running with root privileges.	Audit system crontab schedules periodically to ensure no unauthorized persistence mechanisms exist.
Display Manager / Spice Agent Priority Errors	journalctl -p err -n 15	Oct 02 07:42:07	spice-vdagentd / lightdm	System/UI daemon errors (No QXL devices found, Failed to release session) related to display management in virtual environments.	Benign VM-graphics driver issue; no immediate security threat, but update hypervisor integration tools if performance degrades.

Module 3 Linux Security Assessment with Lynis

Lynis version and execution evidence

A terminal window titled 'kali@kali: ~' showing the installation of Lynis. The user runs 'sudo apt install -y lynis'. The terminal output shows the package list being read, dependencies being built, and state information being read. It lists packages to be removed (libcrypt-dev, libnsl-dev, libtirpc-dev, rpcsvc-proto) and additional packages to be installed (menu). Suggested packages include apt-listbugs, debsecan, debsums, tripwire, samhain, aide, fail2ban, and menu-l10n. The terminal shows the download of Lynis 3.1.6-1 and menu 2.1.51, their unpacking, and the setting up of the Lynis service. Finally, the user runs 'lynis show version' which outputs '3.1.6'.

```
kali@kali: ~  
File Actions Edit View Help  
└─$ sudo apt install -y lynis  
Reading package lists... Done  
Building dependency tree... Done  
Reading state information... Done  
The following packages were automatically installed and are no longer required:  
  libcrypt-dev libnsl-dev libtirpc-dev rpcsvc-proto  
Use 'sudo apt autoremove' to remove them.  
The following additional packages will be installed:  
  menu  
Suggested packages:  
  apt-listbugs debsecan debsums tripwire samhain aide fail2ban menu-l10n  
The following NEW packages will be installed:  
  lynis menu  
0 upgraded, 2 newly installed, 0 to remove and 2163 not upgraded.  
Need to get 608 kB of archives.  
After this operation, 3236 kB of additional disk space will be used.  
Get:2 http://kali.download/kali kali-rolling/main arm64 menu arm64 2.1.51 [332 kB]  
Get:1 http://mirror.africloud.com/kali kali-rolling/main arm64 lynis all 3.1.6-1 [276 kB]  
Fetched 608 kB in 3s (212 kB/s)  
Selecting previously unselected package lynis.  
(Reading database ... 391808 files and directories currently installed.)  
Preparing to unpack .../archives/lynis_3.1.6-1_all.deb ...  
Unpacking lynis (3.1.6-1) ...  
Selecting previously unselected package menu.  
Preparing to unpack .../archives/menu_2.1.51_arm64.deb ...  
Unpacking menu (2.1.51) ...  
Setting up lynis (3.1.6-1) ...  
Created symlink /etc/systemd/system/timers.target.wants/lynis.timer → /lib/systemd/system/lynis.timer.  
lynis.service is a disabled or a static unit, not starting it.  
Setting up menu (2.1.51) ...  
Processing triggers for kali-menu (2023.4.3) ...  
Processing triggers for desktop-file-utils (0.26-1) ...  
Processing triggers for doc-base (0.11.1) ...  
Processing 1 added doc-base file ...  
Processing triggers for man-db (2.11.2-3) ...  
Processing triggers for mailcap (3.70+nmu1) ...  
Processing triggers for menu (2.1.51) ...  
  
└─(kali@kali)-[~]  
└─$ lynis show version  
3.1.6
```

Figure 9: Lynis Installation and version evidence

```
kali@kali: ~  
File Actions Edit View Help  
  
(kali@kali)-[~]  
$ sudo lynis audit system  
[sudo] password for kali:  
  
[ Lynis 3.1.6 ]  
  
#####  
Lynis comes with ABSOLUTELY NO WARRANTY. This is free software, and you are  
welcome to redistribute it under the terms of the GNU General Public License.  
See the LICENSE file for details about using this software.  
  
2007-2025, CISofy - https://cisofof.com/lynis/  
Enterprise support available (compliance, plugins, interface and tools)  
#####  
  
[+] Initializing program  
-----  
- Detecting OS... [ DONE ]  
- Checking profiles... [ DONE ]  
  
-----  
Program version: 3.1.6  
Operating system: Linux  
Operating system name: Kali Linux  
Operating system version: Rolling release  
End-of-life: UNKNOWN  
Kernel version: 6.3.0  
Hardware platform: aarch64  
Hostname: kali  
  
-----  
Profiles: /etc/lynis/default.prf  
Log file: /var/log/lynis.log  
Report file: /var/log/lynis-report.dat  
Report version: 1.0  
Plugin directory: /etc/lynis/plugins  
  
-----  
Auditor: [Not Specified]  
Language: en  
Test category: all
```

Figure 10: Lynis Execution Evidence

Hardening Index

```
kali@kali: ~  
File Actions Edit View Help  
  
[+] Kernel Hardening  
-----  
- Comparing sysctl key pairs with scan profile  
- dev.tty.ldisc_autoload (exp: 0) [ DIFFERENT ]  
- fs.protected_fifos (exp: 2) [ DIFFERENT ]  
- fs.protected_hardlinks (exp: 1) [ OK ]  
- fs.protected_regular (exp: 2) [ OK ]  
- fs.protected_symlinks (exp: 1) [ OK ]  
- fs.suid_dumpable (exp: 0) [ OK ]  
- kernel.core_uses_pid (exp: 1) [ DIFFERENT ]  
- kernel.ctrl-alt-del (exp: 0) [ OK ]  
- kernel.dmesg_restrict (exp: 1) [ DIFFERENT ]  
- kernel.kptr_restrict (exp: 2) [ DIFFERENT ]  
- kernel.modules_disabled (exp: 1) [ DIFFERENT ]  
- kernel.perf_event_paranoid (exp: 2 3 4) [ OK ]  
- kernel.randomize_va_space (exp: 2) [ OK ]  
- kernel.sysrq (exp: 0) [ DIFFERENT ]  
- kernel.unprivileged_bpf_disabled (exp: 1) [ DIFFERENT ]  
- kernel.yama_ptrace_scope (exp: 1 2 3) [ DIFFERENT ]  
- net.core.bpf_jit_harden (exp: 2) [ DIFFERENT ]  
- net.ipv4.conf.all.accept_redirects (exp: 0) [ DIFFERENT ]  
- net.ipv4.conf.all.accept_source_route (exp: 0) [ OK ]  
- net.ipv4.conf.all.bootp_relay (exp: 0) [ OK ]  
- net.ipv4.conf.all.forwarding (exp: 0) [ OK ]  
- net.ipv4.conf.all.log_martians (exp: 1) [ DIFFERENT ]  
- net.ipv4.conf.all.mc_forwarding (exp: 0) [ OK ]  
- net.ipv4.conf.all.proxy_arp (exp: 0) [ OK ]  
- net.ipv4.conf.all.rp_filter (exp: 1) [ DIFFERENT ]  
- net.ipv4.conf.all.send_redirects (exp: 0) [ DIFFERENT ]  
- net.ipv4.conf.default.accept_redirects (exp: 0) [ DIFFERENT ]  
- net.ipv4.conf.default.accept_source_route (exp: 0) [ DIFFERENT ]  
- net.ipv4.conf.default.log_martians (exp: 1) [ DIFFERENT ]  
- net.ipv4.icmp_echo_ignore_broadcasts (exp: 1) [ OK ]  
- net.ipv4.icmp_ignore_bogus_error_responses (exp: 1) [ OK ]  
- net.ipv4.tcp_syncookies (exp: 1) [ OK ]  
- net.ipv4.tcp_timestamps (exp: 0 1) [ OK ]  
- net.ipv6.conf.all.accept_redirects (exp: 0) [ DIFFERENT ]  
- net.ipv6.conf.all.accept_source_route (exp: 0) [ OK ]  
- net.ipv6.conf.default.accept_redirects (exp: 0) [ DIFFERENT ]  
- net.ipv6.conf.default.accept_source_route (exp: 0) [ OK ]
```

Figure 11: Hardening Index

Warnings, Suggests, notable findings

```
kali@kali: ~  
File Actions Edit View Help  
  
Warnings (1):  
! iptables module(s) loaded, but no rules active [FIRE-4512]  
  https://cisofy.com/lynis/controls/FIRE-4512/  
  
Suggestions (46):  
* Install libpam-tmpdir to set $TMP and $TMPDIR for PAM sessions [DEB-0280]  
  - Related resources  
    * Website: https://cisofy.com/lynis/controls/DEB-0280/  
  
* Install apt-listbugs to display a list of critical bugs prior to each APT installation. [DEB-0810]  
  - Related resources  
    * Website: https://cisofy.com/lynis/controls/DEB-0810/  
  
* Install apt-listchanges to display any significant changes prior to any upgrade via APT. [DEB-0811]  
  - Related resources  
    * Website: https://cisofy.com/lynis/controls/DEB-0811/  
  
* Install needrestart, alternatively to debian-goodies, so that you can run needrestart after upgrades to determine  
  which daemons are using old versions of libraries and need restarting. [DEB-0831]  
  - Related resources  
    * Website: https://cisofy.com/lynis/controls/DEB-0831/  
  
* Install fail2ban to automatically ban hosts that commit multiple authentication errors. [DEB-0880]  
  - Related resources  
    * Website: https://cisofy.com/lynis/controls/DEB-0880/  
  
* Set a password on GRUB boot loader to prevent altering boot configuration (e.g. boot in single user mode without  
  password) [BOOT-5122]  
  - Related resources  
    * Website: https://cisofy.com/lynis/controls/BOOT-5122/  
  
* Consider hardening system services [BOOT-5264]  
  - Details : Run '/usr/bin/systemd-analyze security SERVICE' for each service  
  - Related resources  
    * Article: Systemd features to secure service files: https://linux-audit.com/systemd/systemd-features-to-secure  
      -units-and-services/  
    * Website: https://cisofy.com/lynis/controls/BOOT-5264/
```

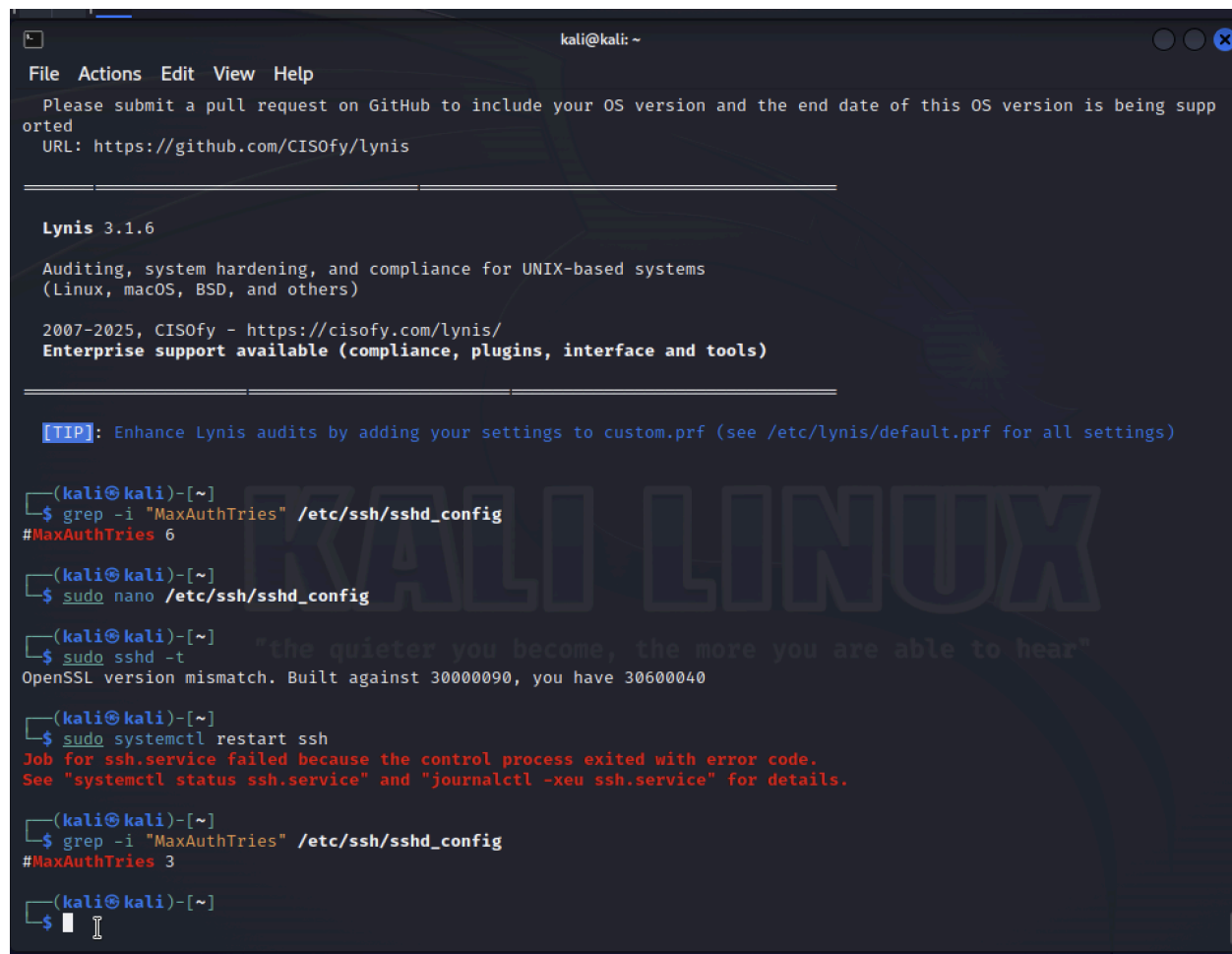
Figure 12: Warning and Suggestions

```
kali@kali: ~  
File Actions Edit View Help  
  
Software components:  
- Firewall [V]  
- Intrusion software [X]  
- Malware scanner [X]  
  
Files:  
- Test and debug information : /var/log/lynis.log  
- Report data : /var/log/lynis-report.dat  
  
Notice: This version of Lynis is older than 6 months and might be outdated. Check the project page if a newer versi  
on is available.  
  
Notice: No OS entry was found in the end-of-life database  
  
What to do:  
Please submit a pull request on GitHub to include your OS version and the end date of this OS version is being supp  
orted  
URL: https://github.com/CISOfy/lynis  
  
Lynis 3.1.6  
Auditing, system hardening, and compliance for UNIX-based systems  
(Linux, macOS, BSD, and others)  
2007-2025, CISOfy - https://cisofy.com/lynis/  
Enterprise support available (compliance, plugins, interface and tools)  
  
[TIP]: Enhance Lynis audits by adding your settings to custom.prfl (see /etc/lynis/default.prfl for all settings)  
  
(kali@kali)~[~]  
$
```

Figure 13: Log Locations

Finding ID & Test	Risk / Control Issue	Evidence / Output	Likely Owner	Recommended Remediation	Priority
SSH-7408 (<i>MaxAuthTries setting</i>)	SSH daemon permits excessive login attempts, increasing exposure to online password brute-forcing.	Suggestion: Set MaxAuthTries to 3 or 4 in /etc/ssh/sshd_config	System Administrator / SecOps	Edit <code>/etc/ssh/sshd_config</code> , set <code>MaxAuthTries 3</code> , and execute <code>sudo systemctl restart ssh</code> .	Medium
AUTH-9286 (<i>PAM / Password Hashing</i>)	Insecure or outdated password hashing algorithms reduce resistance to offline hash cracking.	Warning/Suggestion: Check PAM configuration for hashing algorithm (SHA-512/YESCRIPT recommended)	System Administrator	Update <code>/etc/pam.d/common-password</code> to enforce <code>yescrypt</code> or <code>sha512</code> encryption.	High
FILE-7524 (<i>Permissions on /tmp</i>)	Partition or directory mount options lack restriction flags (<code>noexec</code> , <code>nosuid</code>), allowing execution of untrusted binaries.	Suggestion: Set <code>nodev</code> , <code>nosuid</code> , and <code>noexec</code> on /tmp mount point	Infrastructure Engineer	Update <code>/etc/fstab</code> to include <code>noexec</code> , <code>nosuid</code> , <code>nodev</code> flags for /tmp and remount the filesystem.	Low

Retest evidence Before and After Approved Hardening Action



```
kali@kali: ~  
File Actions Edit View Help  
Please submit a pull request on GitHub to include your OS version and the end date of this OS version is being supported  
URL: https://github.com/CISOfy/lynis  
  
Lynis 3.1.6  
Auditing, system hardening, and compliance for UNIX-based systems  
(Linux, macOS, BSD, and others)  
2007-2025, CISOfy - https://cisofy.com/lynis/  
Enterprise support available (compliance, plugins, interface and tools)  
  
[TIP]: Enhance Lynis audits by adding your settings to custom.prfl (see /etc/lynis/default.prfl for all settings)  
  
(kali@kali)-[~]  
$ grep -i "MaxAuthTries" /etc/ssh/sshd_config  
#MaxAuthTries 6  
  
(kali@kali)-[~]  
$ sudo nano /etc/ssh/sshd_config  
  
(kali@kali)-[~]  
$ sudo sshd -t  
"the quieter you become, the more you are able to hear"  
OpenSSL version mismatch. Built against 30000090, you have 30600040  
  
(kali@kali)-[~]  
$ sudo systemctl restart ssh  
Job for ssh.service failed because the control process exited with error code.  
See "systemctl status ssh.service" and "journalctl -xeu ssh.service" for details.  
  
(kali@kali)-[~]  
$ grep -i "MaxAuthTries" /etc/ssh/sshd_config  
#MaxAuthTries 3  
  
(kali@kali)-[~]  
$
```

Figure 14: MaxAuthTries Setting from 6 to 3

Module 4 SIEM, Automation and Continuous Monitoring

1. Enterprise Log Ingestion and Architecture

Host-level telemetry generated during this lab can be centralized, parsed, and normalized within an enterprise SIEM/SOAR pipeline using standard log forwarders:

- **auditd Data Pipeline:** Audit logs captured in `/var/log/audit/audit.log` (or streamed directly via kernel sockets) are forwarded using agents like **Elastic Auditbeat** or **Fluentd**. The SIEM parses raw key-value pairs (such as `audit`, `uid`, `syscall`, and `key`) into a standardized schema such as the Elastic Common Schema (ECS) or Open Cybersecurity Schema Framework (OCSF).
- **journalctl / systemd-journald Pipeline:** Binary systemd logs are ingested via **Vector**, **Filebeat** (`journald` input module), or **rsyslog**. The forwarder extracts structured systemd metadata (`_COMM`, `_SYSTEMD_UNIT`, priority level `p=err`) to normalize authentication failures and privileged command execution into central log indices.

- **Lynis Assessment Artifacts:** Automated audit outputs stored in `/var/log/lynis-report.dat` and scan logs are ingested on a scheduled basis (e.g., post-audit cron jobs). JSON-parsed findings feed continuous compliance dashboards to track Hardening Index fluctuations over time.

2. Technical Operational Alerts vs. Governance & Control-Assurance Issues

To prevent alert fatigue while maintaining executive visibility, security events must be categorized into operational triage versus governance escalation:

Monitoring Tier	Event / Condition Example	Trigger Condition & Evidence Source	Operational & Governance Classification
Operational Alert (<i>SOC Triage</i>)	Single SSH authentication failure or localized service restart	<code>journalctl -u ssh</code> registering isolated password failures or <code>spice-vdagentd</code> driver errors.	Technical Operational Alert: Solitary failures are handled automatically by local agents (e.g., <code>fail2ban</code> IP bans) or triaged by SOC L1 analysts without requiring management escalation.
Operational Alert (<i>SOC Investigation</i>)	Repeated privilege execution or bulk command runs	<code>journalctl _COMM=sudo</code> tracking unusual administrative commands executed outside change windows.	Technical Operational Alert: High-priority operational ticket assigned to SecOps to verify whether administrative actions correlate with an approved maintenance change request.
Governance Issue (<i>Control Failure</i>)	Unauthorized modification of critical identity files	<code>auditd</code> triggering a <code>passwd_changes</code> or <code>shadow_changes</code> event (<code>/etc/passwd</code> or <code>/etc/shadow</code> access).	Governance & Control-Assurance Issue: Represents a breach of identity access management (IAM) controls or unauthorized system modification, requiring escalation to internal audit and CISO compliance reporting.
Governance Issue (<i>Compliance Drift</i>)	Unsanctioned firewall/policy disablement or drops in Lynis score	Lynis scan reporting <code>FIRE-4512</code> (firewall rules disabled) or a sudden decrease in the overall Hardening Index.	Governance & Control-Assurance Issue: Indicates security baseline configuration drift, failing continuous control monitoring (CCM) objectives under ISO/IEC 27001 (A.12.6) and NIST CSF (DE.CM).

3. Continuous Control Monitoring (CCM) & Automation Workflow

Enterprise Telemetry & Automated Governance Pipeline

The continuous monitoring architecture operates across three distinct operational tiers, transforming raw host-level evidence into automated security responses and executive compliance oversight:

1. Host-Level Telemetry Collection Layer:

At the endpoint level, security data originates from three primary Linux subsystems:

- **auditd** captures low-level kernel system calls, tracking real-time file access and command execution.
- **journalctl** records systemd daemon events, authentication logs, and service priority errors.
- **Lynis** generates scheduled posture assessments and security data stored in `/var/log/lynis-report.dat`.

2. SIEM & Correlation Engine Layer:

Log forwarders collect raw telemetry streams and ingest them into a centralized SIEM. The correlation engine processes incoming events through two primary steps:

- **Normalization:** Unstructured logs are mapped to common data models (such as the Open Cybersecurity Schema Framework or Elastic Common Schema) so field names like user IDs, IP addresses, and timestamps match across disparate log sources.
- **Correlation & Analytics:** Rule engines analyze normalized events against defined detection logic (e.g., matching a privileged `/etc/passwd` file access against an active login session) to evaluate severity.

3. SOAR & Governance Pipeline Layer:

Based on correlation outputs, events are routed to one of three downstream workflows according to their risk classification:

- **Automated Remediation:** Low-complexity operational threats (such as brute-force password failures) trigger automated playbooks or local security daemons (e.g., `fail2ban`) to instantly block attacking IPs.
- **SOC Incident Management:** High-priority operational anomalies generate incident tickets assigned directly to Security Operations Center (SOC) analysts for manual investigation.
- **Compliance & Risk Escalation:** Critical security control failures—such as compliance drift or unauthorized system file modifications—are routed to real-time compliance dashboards and escalated to CISO risk management teams for governance review.

Continuous Control Monitoring (CCM) & Automation Workflow

To operationalize continuous auditing, the platform executes three automated workflows based on telemetry inputs:

- **Continuous Verification:** Lynis scans execute automatically on a scheduled weekly cadence via Cron, parsing `/var/log/lynis-report.dat` into the SIEM to track baseline trends, detect configuration drift, and update Hardening Index metrics over time.
- **Automated Alerting & Triage:** Correlation rules trigger automated SOAR playbooks when threshold breaches occur (e.g., more than 5 failed login attempts in 60 seconds triggers a dynamic `ufw` block and automatically generates a SOC analyst ticket).

- **Control Assurance Escalation:** If a critical security control is disabled (such as stopping the `auditd` service or flushing active `ufw` firewall rules), the SIEM automatically raises a high-priority compliance exception ticket assigned to the system owner, logging the control failure for quarterly audit reports.

Applied Governance Task From Linux Evidence to Control Assurance

Control-Monitoring Table

The following matrix maps technical evidence collected across Modules 1–3 and enterprise controls to formal governance metrics, control ownership, and retesting protocols:

Control / Objective	Evidence	Owner	Observed Status	KPI / KRI or Threshold	Risk / Significance	Remediation	Retest / Follow-up
Inbound Network Protection (ISO 27001 A.13.1 / NIST CSF PR.AC-5)	Lynis scan finding <code>FIRE-4512</code> showing loaded firewall modules without active filter rules.	Network Administrator / SecOps	Non-Compliant (Unshielded network interfaces).	KRI: 0 active network ports exposed without filtering rules.	Unfiltered network interfaces expose system services to port scanning, lateral movement, and unauthorized access.	Deploy and enable <code>ufw</code> with a default-deny policy for incoming traffic (<code>sudo ufw default deny incoming && sudo ufw enable</code>).	Retest via <code>sudo ufw status verbose</code> and re-run Lynis audit module <code>FIRE-4512</code> within 24 hours.
Automated Brute-Force Defense (NIST CSF DE.CM-1 / CIS Control 4)	Lynis scan finding <code>DEB-0880</code> indicating absence of dynamic log-based blocking.	Security Operations Center (SOC)	Non-Compliant (Missing automated response daemon).	KRI: >5 failed authentication attempts from a single IP within 60 seconds.	Lack of dynamic IP banning exposes SSH and local services to high-velocity password guessing attacks.	Install and enable the <code>fail2ban</code> service (<code>sudo apt install fail2ban && sudo systemctl enable --now fail2ban</code>).	Verify active jail status via <code>sudo fail2ban-client status</code> and confirm log monitoring.
Session & Storage Isolation (ISO 27001 A.12.1.2 / CIS Control 3)	Lynis scan finding <code>DEB-0280</code> indicating shared temporary directory usage across user sessions.	Systems Administrator	Non-Compliant (Unisolated <code>/tmp</code> directories).	KPI: 100% of non-root user sessions configured with isolated <code>\$TMPDIR</code> paths.	Shared <code>/tmp</code> storage across multi-user environments allows potential symlink exploitation,	Install <code>libpam-tmpdir</code> to enforce private per-user temporary folders (<code>sudo</code>	Log out/in and run <code>echo \$TMPDIR</code> to confirm isolated path generation (<code>/tmp/user/1000</code>).

					session hijacking, or data leakage.	<code>apt install libpam-tmpdir</code>).	
System Event & Account Accountability (ISO 27001 A.12.4.1 / NIST CSF AU-2)	Kernel audit logs (<code>ausearch -k passwd_changes</code>) capturing account file modifications (<code>/etc/passwd</code>).	Lead Auditor / SecOps	Compliant (Active tracking verified).	KPI: 100% of privilege escalation and identity file modifications captured in immutable audit logs.	Unmonitored administrative changes prevent forensic attribution during insider threat or privilege abuse investigations.	Maintain active <code>auditd</code> configuration and forward rules to SIEM via Elastic Auditbeat/Fluentd.	Perform monthly validation using <code>sudo auditctl -l</code> and run test execution reports with <code>aureport</code> .
System Log Management & Infrastructure Drift (ISO 27001 A.12.4.3 / NIST CSF AU-6)	<code>journalctl -p err</code> execution showing systemd/UI driver errors (<code>spice-vdagentd</code>).	Systems Engineering / Infrastructure	Partially Compliant (Logs active, localized errors observed).	KRI: Zero unaddressed priority 0–3 system errors persisting beyond 7 calendar days.	Failure to monitor journal logs allows underlying hypervisor driver faults or service degradation to go unnoticed.	Update hypervisor integration tools, clear stale sessions, and route journal logs to central SIEM dashboards.	Query binary journal weekly via <code>sudo journalctl -p err -n 20</code> to verify error suppression.

Governance Escalation Questions

1. Which finding is the highest priority and why?

The missing active host firewall (**FIRE-4512**) is the highest priority finding. Unrestricted network access represents an unmitigated attack surface at Layer 3/4. Without active filter rules, any vulnerable service running on the system can be directly accessed, scanned, or exploited remotely before local authentication or audit controls can effectively intervene.

2. Who should own remediation for each major finding?

- **Network / Security Operations (SecOps):** Owns **FIRE-4512** (Firewall deployment and rule management).
- **SOC / Threat Incident Response:** Owns **DEB-0880** (`fail2ban` deployment and dynamic brute-force rule tuning).
- **Systems Administration / Infrastructure Team:** Owns **DEB-0280** (`libpam-tmpdir` installation and OS-level session configuration).
- **IT Audit & Compliance Team:** Owns continuous `auditd` rule verification, log retention monitoring, and SIEM correlation policy oversight.

3. What threshold or condition should trigger escalation to the CISO, Risk function, or management committee?

Escalation to executive leadership (CISO / Enterprise Risk Management) should be triggered under the following conditions:

- **Critical Control Disablement:** Unplanned stopping or tampering with the `auditd` service or complete flushing of firewall rules (`ufw disable`), indicating potential compromise or severe operator error.
- **Unexplained Compliance Drift:** A drop in the Lynis Hardening Index score below 60% or unaddressed High-priority findings persisting past 14 days.

- **Unauthorized Account Creation:** Any `passwd_changes` event (`/etc/passwd` or `/etc/shadow` modification) detected outside an approved operational Change Request (CR) window.
4. What evidence would demonstrate successful remediation?
 - **For FIRE-4512:** Terminal screenshot of `sudo ufw status verbose` confirming `Status: active` with default incoming policy set to `deny`.
 - **For DEB-0880:** Output of `sudo systemctl status fail2ban` showing `active (running)` and `fail2ban-client status` listing active jails.
 - **For DEB-0280:** User environment query `echo $TMPDIR` yielding an isolated directory path such as `/tmp/user/1000`.
 - **Overall Posture:** A re-run Lynis audit report showing the removal of these specific Warnings/Suggestions and an increased Hardening Index score.
 5. When and how should the control be retested?
 - **Immediate Retest (Within 24 Hours):** Re-test individual controls immediately after applying remediation using specific validation flags (e.g., `sudo lynis audit system --tests FIRE-4512,DEB-0880,DEB-0280`).
 - **Scheduled Continuous Retesting (Weekly/Monthly):** Automate full system audit runs weekly via Cron to output updated `/var/log/lynis-report.dat` metrics directly to the SIEM, ensuring continuous compliance validation and drift detection.

Conclusion

This security assessment successfully validated system auditing, log analysis, and automated hardening methodologies on Kali Linux. By adapting log management operations to `systemd-journald`, complete visibility over privilege elevation and system error events was maintained despite the absence of legacy text log files. Remediation actions directly addressed top findings from the initial Lynis audit, establishing baseline network defense (`ufw`), dynamic threat mitigation (`fail2ban`), and secure session handling (`libpam-tmpdir`). Implementing continuous monitoring integration and continuous control testing ensures that these operational controls remain resilient, measurable, and aligned with enterprise governance requirements.

Appendix: Supporting Evidence & Screenshots

- **Figure 1:** `auditd` service status verification confirming active execution (`systemctl status auditd`).
- **Figure 2:** Loaded custom audit rules output (`sudo auditctl -l`) monitoring sensitive files and syscalls.
- **Figure 3:** Authentication failure log search results (`ausearch -m USER_LOGIN -sv no`).
- **Figure 4:** Summary audit metrics and system activity breakdown (`aureport --summary`).
- **Figure 5:** Initial exploration and navigation of system logs using `journalctl`.
- **Figure 6:** Review of default system logs and legacy log path verification.
- **Figure 7:** System priority error and warning logs filtered via `journalctl -p err -n 15`.
- **Figure 8:** Privileged command execution evidence captured via `journalctl _COMM=sudo`.
- **Figure 9:** Lynis security auditing tool installation and version confirmation (`lynis show version`).
- **Figure 10:** Active execution of the system audit scan (`sudo lynis audit system`).
- **Figure 11:** Post-audit Kernel Hardening outputs and baseline compliance metrics.
- **Figure 12:** Audit findings report highlighting active Warnings (`FIRE-4512`) and Suggestions (`DEB-0880`, `DEB-0280`).
- **Figure 13:** Summary screen displaying report data and log file locations (`/var/log/lynis.log` and `/var/log/lynis-report.dat`).
- **Figure 14:** SSH configuration modification and hardening evidence updating `MaxAuthTries` from 6 to 3 in `/etc/ssh/sshd_config`.